CodeSentinel

A Multi-Agent Retrieval-Augmented Generative AI System for Automated Code Review and Vulnerability Detection

Final Project Technical Report

Aravind Balaji

M.S. Information Systems

Northeastern University, College of Engineering

balaji.ara@northeastern.edu

INFO 7375: Prompt Engineering and Generative AI

Instructor: Professor Nik Bear Brown

Spring 2026

Submission: April 24, 2026

Abstract

Large language models have rapidly become competent code reviewers, yet a single prompt to a single model routinely produces three failure modes that matter in practice: hallucinated vulnerabilities, silent omissions of real defects, and findings that cannot be traced to an authoritative source. CodeSentinel is a multi-agent generative AI system that addresses these failure modes architecturally rather than through better prompting alone. The system orchestrates three specialized agents, a Security Sentinel, a Code Quality Auditor, and an Evaluator Guardian, through a LangGraph directed graph with conditional routing and a bounded retry loop. The Security Sentinel grounds every vulnerability claim in a local retrieval index built over OWASP Top 10 2025 and a curated CWE taxonomy subset. The Evaluator Guardian acts as an internal adversary, rejecting findings that lack evidence, citations, or concrete remediation, with both a programmatic check and an LLM semantic check. A synthetic data generator produces evaluation samples using an independent verifier to prevent the generator from gaming the test. A parallel reinforcement learning demonstration module (UCB-1 contextual bandit over prompt variants, REINFORCE policy gradient over routing decisions) shows the optimization surface for future integration; it is not wired into the agent graph in this release, and the reported benchmark numbers do not depend on it. On a ten-sample hand-labeled toy suite, the three-agent architecture improves true positive rate from 0.750 to 1.000 over a single-prompt baseline that uses the same underlying model, with zero false positives on both systems. On a twenty-sample paired suite built in the spirit of the OWASP Benchmark methodology with deliberate false-positive traps, the multi-agent system achieves true positive rate 1.000 and false positive rate 0.182 against baseline 0.333 and 0.571; McNemar's exact two-sided $p = 0.0312$, significant at $\alpha = 0.05$. CWE classification accuracy is 1.0 on both suites. All thirty-five unit tests pass on a clean clone. The claim is not that a new model has been built; it is that when an LLM application is rearchitected into specialized, grounded, adversarially-reviewed agents, the gains come from the architecture, not from the model, and they compose with any model the field produces next.

Keywords

Multi-agent systems, retrieval-augmented generation, LangGraph, prompt engineering, code review, vulnerability detection, OWASP, CWE, synthetic data generation, reinforcement learning, UCB-1, REINFORCE.

Table of Contents

1. Introduction and Motivation
2. Problem Statement and Objectives
3. Related Work
4. System Architecture
5. Prompt Engineering Strategy
6. Retrieval-Augmented Generation Pipeline
7. Synthetic Data Generation and Verification
8. Reinforcement Learning Enhancement Layer
9. Implementation Details
10. Evaluation Methodology and Measured Results
11. Challenges and Solutions
12. Ethical Considerations and Limitations
13. Future Work
14. Conclusion
15. References
Appendix A: Prompt Template Excerpts
Appendix B: Per-Sample Benchmark Results

1. Introduction and Motivation

Software vulnerabilities remain one of the most persistent sources of operational and security risk in modern systems. The OWASP Top 10 list, first published in 2003 and periodically revised, continues to be dominated by the same categories of defect: injection, broken access control, insecure deserialization, and cryptographic failures. This persistence is not because the categories are unknown. It is because code review, at scale, is expensive, inconsistent, and fatiguing for human reviewers, and because the volume of code shipped per engineer per day has grown far faster than the number of trained security reviewers.

Generative AI introduces a new class of tool into this problem. A sufficiently capable large language model, prompted correctly, can identify many of the same defects a trained human reviewer would, in seconds rather than hours. In practice, however, the naive deployment of a single LLM call for code review produces an output with three structural weaknesses.

- First, findings are ungrounded. The model may assert that a line of code contains SQL injection, but nothing forces the assertion to be anchored to an authoritative reference such as OWASP A03:2025 or CWE-89. Without grounding, the model is free to invent plausible sounding but incorrect findings.
- Second, the output is monolithic. A single pass generates security findings, style findings, and architectural suggestions together, with no internal adversary to challenge any individual claim. False positives flow through to the user at the same rate as true positives.
- Third, errors are untraceable. When a finding turns out to be wrong, there is no record of what information the model had, which prompt produced it, or what alternatives were considered and rejected.

CodeSentinel responds to these three weaknesses. The system is organized around three ideas. Agents are specialized, each with a narrow mandate and a corresponding system prompt, so each reasoning step is constrained and auditable. Findings are grounded, meaning every security claim must cite a retrieved passage from an authoritative source or it is rejected before reaching the user. Outputs are adversarially reviewed by a dedicated Evaluator Guardian, using both a programmatic validation layer and an LLM semantic layer, and the Evaluator can route findings back for revision with structured feedback.

The project extends beyond these core ideas into two research directions. The first is synthetic data generation: because labeled vulnerability corpora are scarce and expensive to curate, CodeSentinel includes a pipeline that generates paired vulnerable and safe code samples with ground-truth labels, verified by an independent regex-based detector that has no shared context with the generator. The second is a reinforcement learning enhancement layer: a UCB-1 contextual bandit selects among prompt variants based on input context, and a REINFORCE policy gradient adapts the routing behavior of the LangGraph controller based on the Evaluator's reward signal.

2. Problem Statement and Objectives

2.1 Problem Statement

Given an input source file or snippet, produce a code review report that identifies security vulnerabilities grounded in OWASP Top 10 2025 and CWE taxonomy citations, identifies code quality and maintainability

issues grounded in established style guides, and rejects any finding that is not supported by retrieved evidence or that lacks a concrete remediation. The system must be faster and more consistent than a human expert, and more precise than a single-prompt LLM baseline on the same underlying model.

2.2 Objectives

- Build a multi-agent orchestration using LangGraph in which specialization, routing, and bounded retry are first-class features of the architecture.
- Ground every security finding in a retrieval step over a local knowledge base built from OWASP 2025 and CWE, with citations exposed in the final report and verified by the Evaluator.
- Evaluate the system against a single-prompt baseline on the same LLM, using a labeled evaluation suite, and report the result honestly regardless of direction.
- Demonstrate that the agent system itself can be treated as a learnable object, by introducing an RL layer that improves prompt and routing decisions based on the Evaluator's reward signal.

2.3 Non-Objectives

The project does not attempt to replace expert human review for systems under regulatory audit. It does not attempt to detect semantic logic bugs that are undetectable from source alone. It does not attempt to generalize beyond the languages and frameworks represented in the evaluation suite. Those boundaries are drawn intentionally so that the claims made in Section 10 can be interpreted within a clearly defined scope.

2.4 Rubric Compliance

The INFO 7375 assignment requires at least two of five generative AI components. CodeSentinel implements four, with the fifth (multimodal integration) out of scope for text-based code review. Prompt engineering is realized as three role-specialized system prompts in graph/prompts/, each with explicit input and output contracts, refined iteratively against a held-out validation set; this is covered in Section 5. Retrieval-augmented generation is realized as a local vector store over 56 passages from OWASP Top 10 2025, CWE taxonomy entries, and language-specific patterns, with semantic-boundary chunking, two-pass retrieval, lexical rerank, and citation enforcement at the Evaluator; this is covered in Section 6. Synthetic data generation is realized as a template-based generator for 15 CWE classes with an independent regex-based verifier that operates without shared context with the generator; this is covered in Section 7. Reinforcement learning is included as a parallel demonstration module with a UCB-1 bandit over prompt variants and a REINFORCE policy gradient over routing decisions, documented fully in Section 8 with an explicit scope note that the modules are not integrated into the production agent graph in this release. Every rubric claim in this report is backed by runnable code in the repository; no claim is asserted without a file reference.

2.5 Comparison With Industry Products

CodeSentinel is a course project, not a competitor to mature production static-analysis tools. Positioning it honestly relative to the state of the art matters for interpreting the results in Section 10. Semgrep uses rule-based pattern matching and has more than a decade of community-developed rules; it outperforms any LLM-based system on rule-coverage breadth and on pattern-specified findings. GitHub CodeQL uses

dataflow and taint analysis and has the depth of semantic reasoning that CodeSentinel lacks. Snyk Code combines trained models with dataflow analysis and has the supply-chain visibility that CodeSentinel does not cover. Among LLM-based code review tools, Bito's CodeReviewAgent and Tabnine's Code Review Agent both use single-prompt architectures and do not publish adversarial-evaluation findings or standardized benchmarks. The contribution CodeSentinel makes is not in any of these axes. It is in closing specific failure modes that single-prompt LLM review exhibits: hallucinated vulnerabilities (closed by the citation-required retrieval), silent omissions (closed by the specialized Security Sentinel with OWASP grounding), and untraceable findings (closed by the RAG-source field required on every finding). The target comparison, specified in Section 10.10, is not with Semgrep as a replacement but with Semgrep as a complementary system with different strengths: Semgrep for high-recall low-cost triage, CodeSentinel for lower-recall higher-context deep review with verifiable provenance.

2.6 Portfolio Framing

Beyond the INFO 7375 rubric, CodeSentinel is structured to demonstrate a set of skills that appear repeatedly in AI engineering and software security job postings in the 2026 market: multi-agent LLM orchestration with explicit state and routing, retrieval-augmented generation with production-grade fallback and citation enforcement, rigorous LLM evaluation with paired statistical testing and power analysis, security domain knowledge grounded in OWASP and CWE taxonomies, and engineering discipline visible in thirty-five unit tests, three-tier dependency fallback, deterministic mock mode for reproducibility, and committed benchmark outputs. The architectural pattern the project demonstrates, which is specialization plus grounding plus adversarial validation, is the same pattern Anthropic's Project Glasswing applies at industrial scale; framing the project within that lineage makes its ambition legible without overstating its capability.

3. Related Work

3.1 Static Analysis and Rule-Based Code Review

Tools such as Bandit for Python, SonarQube, Semgrep, and CodeQL encode known vulnerability patterns as rules and match them against source code. These tools are fast, deterministic, and trusted in continuous integration pipelines. Their limitation is that they detect only what their rules encode and struggle with context-dependent defects where a line is vulnerable in one usage and safe in another. CodeSentinel complements rather than replaces these tools by using an LLM-driven reasoning layer to interpret context, with the OWASP and CWE knowledge base providing a rule-like grounding.

3.2 LLM Agents and Multi-Agent Frameworks

LangChain, LangGraph, CrewAI, and AutoGen all provide abstractions for building multi-agent systems on top of large language models. LangGraph is chosen for CodeSentinel because its graph-based model of state and transitions maps cleanly onto the notion of a bounded retry loop with conditional routing, which is central to the Evaluator mechanism. The graph is explicit, inspectable, and testable, which matters for a system whose correctness guarantees depend on a feedback loop that must terminate.

3.3 Retrieval-Augmented Generation for Domain Grounding

RAG has become the default approach for making LLM outputs verifiable against a corpus. CodeSentinel applies this pattern to a curated security knowledge base and adds a citation-required policy enforced at the Evaluator: findings without valid rag_source fields are rejected programmatically before any LLM semantic review runs.

4. System Architecture

4.1 High-Level View

CodeSentinel is organized as a LangGraph directed graph with a shared typed state. The entry node is the Security Sentinel, which performs RAG-grounded vulnerability detection. Its output feeds into the Code Quality Auditor, which performs style and maintainability review. Both outputs converge at the Evaluator Guardian, which decides whether the accumulated findings are acceptable. On acceptance, the graph terminates and a final report is assembled. On rejection, the graph routes back to the Security Sentinel with structured feedback, up to a configurable retry limit that acts as a circuit breaker. The default retry limit is three.

4.2 Shared State

```
class CodeSentinelState(TypedDict, total=False):
    input_code: str
    language: str
    retrieved_passages: List[RetrievedPassage]
    security_findings: List[SecurityFinding]
    quality_findings: List[QualityFinding]
    evaluator_verdict: Optional[EvaluatorVerdict]
    retry_count: Dict[str, int]
    evaluator_feedback: Optional[str]
    final_report: Optional[str]
    trace: List[str]
```

4.3 Conditional Routing and the Circuit Breaker

After the Evaluator Guardian runs, a conditional edge inspects its verdict. If the verdict is APPROVED, the graph routes to the report assembler and terminates. If the verdict is REJECTED and the per-agent retry counter is below its limit, the graph routes back to the Security Sentinel with the Evaluator feedback set in state. If the retry limit is reached, the graph routes to the assembler anyway and the resulting report notes the unresolved findings. Bounded termination is a correctness property, not a convenience. Without the circuit breaker, an early version of the implementation entered an oscillation in which the Evaluator alternated between approving and rejecting the same finding on successive passes.

4.4 Agent Contracts

Each agent's output is validated against a Pydantic schema at the boundary. SecurityFinding requires finding_id, category, cwe_id, owasp_ref, severity, confidence, evidence, fix, and rag_source. QualityFinding requires finding_id, category, severity, confidence, evidence, rationale, and suggested_refactor. EvaluatorVerdict requires overall_decision, per-finding decisions, and rationale. Schema violations at any boundary are surfaced as rejection reasons. Schemas degrade to dataclass-based validation if Pydantic is unavailable.

5. Prompt Engineering Strategy

Prompt engineering is applied systematically rather than ad hoc. Each of the three agents has a dedicated system prompt, versioned under source control, that encodes four ingredients: the role definition, the input contract, the output contract, and the failure modes the agent must guard against. The prompts were iteratively refined against a held-out set of samples separate from the final evaluation suite, which is the methodology used here in place of weight-level fine-tuning.

5.1 Security Sentinel Prompt

Establishes the agent as a senior application security engineer whose only task is to identify vulnerabilities. Specifies that every finding must cite a retrieved passage, that findings without concrete evidence must be suppressed rather than invented, and that the output must be valid JSON conforming to the SecurityFinding schema. Includes negative examples drawn from actual early failure modes, such as claiming SQL injection on parameterized queries that correctly use placeholders.

5.2 Code Quality Auditor Prompt

Establishes the agent as a pragmatic staff engineer whose goal is to improve readability and maintainability without nitpicking. Instructs the agent to cite the relevant style guide rule for each finding, to prioritize findings by their actual impact on maintainability, and to produce at most ten findings per file. Explicitly excludes security categories, to avoid overlap with the Security Sentinel.

5.3 Evaluator Guardian Prompt

The most adversarial of the three. Instructs the agent to assume upstream agents have made mistakes and that its job is to find those mistakes. Specifies five explicit rejection conditions: missing citation, missing evidence, missing remediation, schema violation, and internal contradiction. For each rejected finding, requires the Evaluator to produce structured feedback with the specific rejection reason and a corrective instruction.

5.4 Iterative Prompt Refinement as Systematic Tuning

Rather than training or fine-tuning model weights, the project applies a systematic prompt-tuning methodology that treats the prompt as the unit of optimization. A held-out validation set was used to measure, across prompt versions, the true positive rate and false positive rate of each agent. Each prompt went through three documented revisions. This procedure is adjacent in spirit to supervised fine-tuning: a

training signal drives iterative improvement of a parameterized object. Section 8 extends this approach with a reinforcement learning loop that makes the prompt-selection process adaptive at inference time.

6. Retrieval-Augmented Generation Pipeline

6.1 Knowledge Base Construction

The CodeSentinel knowledge base contains 56 passages across three files. OWASP Top 10 2025 contributes 10 category-level entries. A curated CWE taxonomy subset contributes 29 entries for the weaknesses most commonly observed in application code. Language-specific vulnerability patterns, authored as part of this project, contribute 17 entries covering Python pickle deserialization, Node.js eval usage, Java JDBC concatenation, and similar.

6.2 Chunking Strategy

The corpus is chunked by semantic boundary rather than by fixed token count. OWASP and CWE entries are chunked at the category level so that an entry for A03:2025 Injection stays together as a single retrievable unit. Style guide rules are chunked per rule. Boundary-aware chunking measurably improves retrieval precision because a single retrieval returns a complete, self-contained passage rather than a fragment.

6.3 Embedding and Storage Backend

The pipeline implements a triple-fallback retrieval backend. The preferred path is ChromaDB with sentence-transformers (all-MiniLM-L6-v2), producing 384-dimensional vectors locally on CPU. If ChromaDB is unavailable, scikit-learn TF-IDF is used. If scikit-learn is unavailable, a pure-Python TF-IDF implementation is used. All three expose the same Retriever interface. The fallback design means the pipeline runs end-to-end on any machine without heavy dependencies, which is important for reproducibility and testing.

6.4 Two-Pass Retrieval

At query time, the Security Sentinel constructs a query from the input language plus extracted suspicious keywords plus the first 800 characters of code. This query is embedded and used to retrieve the top-2k passages by similarity. A second-pass lexical rerank then boosts passages whose title matches query keywords, which corrects a real failure mode in pure semantic retrieval where generic security passages outrank specific ones. The rerank dictionary is tuned: for example, the presence of pickle in the query boosts CWE-502 and PY-02 passages above the generic A08 entry.

6.5 Citation Policy

The Security Sentinel prompt requires that each finding include a rag_source field containing the document and passage identifier that supports the finding. The Evaluator rejects any finding where this field is empty, where the cited passage is not in the retrieved context, or where (in LLM semantic mode) the passage's

content does not mention the claimed weakness. This is the primary mechanism by which CodeSentinel resists hallucinated findings.

7. Synthetic Data Generation and Verification

7.1 Motivation

The initial evaluation suite contains ten hand-labeled samples. While sufficient for a proof of concept, ten samples are modest for measuring precision and recall with tight confidence intervals. Labeled vulnerability corpora at larger scale are either expensive to curate or come with significant license restrictions. Synthetic data generation was therefore introduced as a deliberate evaluation component.

7.2 Generation Pipeline

The synthetic pipeline (synth/generate.py) maintains a library of 15 CWE template pairs spanning Python, JavaScript, and Java. For each entry, the generator produces two artifacts: a vulnerable code sample exhibiting the weakness in realistic context, and a safe variant that uses the same general structure but avoids the weakness. Templates include realistic variable names, common frameworks such as Flask and Express, and surrounding context rather than minimal textbook examples. A total of 30 samples are produced for a single default run: 15 vulnerable, 15 safe.

7.3 Independent Verification

Every generated sample is verified by synth/verify.py before entering the evaluation suite. The verifier uses a set of regex-based detectors for each CWE, independent of the generator's templates and prompts. For vulnerable samples, the verifier requires that at least one detector fires for the claimed CWE. For safe variants, no detectors must fire. The verifier has no shared context with the generator, which is the architectural separation that prevents the generator from gaming the test. Samples that fail verification are moved to a separate rejected file for inspection.

7.4 Verification Outcome

On the default run, 29 of 30 samples passed verification, a 96.7 percent pass rate. The one rejected sample was a safe-variant CWE-915 (prototype pollution) example whose specific Object.assign form did not match the verifier's detector pattern. The rejection is an advertisement that the verifier is genuinely independent; had the verifier been a copy of the generator, nothing would be rejected.

7.5 Ethical Safeguards on Synthetic Data

Templates explicitly avoid producing real exploit payloads, real credentials, or samples targeting specific production systems. Generated samples are stored only under eval/datasets/, never in a path a developer might accidentally execute. The point of the synthetic suite is to measure detection quality, not to serve as an exploit library.

8. Reinforcement Learning Enhancement Layer

Scope and integration status. The reinforcement learning layer described in this section is a parallel demonstration module. The UCB-1 bandit and REINFORCE policy-gradient implementations live in the rl/ package as standalone programs with their own synthetic reward surfaces. They converge on those surfaces as reported below, but they are not wired into the production agent graph in this release. The benchmark numbers reported in Section 10 do not include any RL contribution; they reflect the architecture described in Sections 4 through 7 running with fixed prompts and deterministic routing. Wiring the bandit into prompt selection and the policy gradient into the Evaluator-rejection routing is a concrete, scoped task that is deferred to future work and discussed in Section 13. The rationale for documenting the RL layer here rather than folding it into future work is pedagogical: the agent graph has natural decision points that map cleanly onto standard RL formulations, and making those formulations explicit in this report is useful for a reader who wants to understand why multi-agent systems built on LLMs are a promising substrate for reinforcement learning over time. The claim is not that this system has learned anything from experience; the claim is that the formulation is sound and the modules converge on synthetic reward surfaces that match the structure of the real decision problems.

8.1 Rationale

The multi-agent system has two natural decision points that can be treated as learnable policies. The first is prompt selection: each agent has multiple prompt variants tuned manually, and which variant performs best may depend on input context (language, complexity, vulnerability class). The second is routing: when the Evaluator rejects a finding, the graph may benefit from routing to a specific prompt variant based on the rejection reason rather than always defaulting to the same upstream entry. In both cases, the Evaluator's verdict already provides a natural reward signal.

8.2 UCB-1 Contextual Bandit for Prompt Selection

For each agent, a UCB-1 contextual bandit (rl/bandit.py) selects among its prompt variants at the start of each run. The context vector is discretized into 60 buckets: 4 languages times 3 complexity classes times 5 vulnerability classes. Per-bucket UCB-1 is tractable without a neural function approximator. Reward is 1 if the Evaluator approves on first pass, 0 otherwise. The exploration constant begins at sqrt(2) and anneals toward 0.1 as per-context pull count grows, so exploration tapers off once confidence intervals become narrow. A demo run over 200 synthetic rounds shows correct convergence to the best arm per context.

8.3 REINFORCE Policy Gradient for Routing

The routing decision after an Evaluator rejection is parameterized by a softmax over four actions (three Security Sentinel variants plus an explicit skip-to-assemble) conditioned on a 7-dimensional one-hot feature vector over rejection reasons. Weights are trained using REINFORCE with a moving-average baseline. The network is intentionally small, with fewer than 50 parameters, so training is fast and overfitting on small samples is controllable. A demo run over 600 training steps recovers the correct action-per-reason mapping for six of seven rejection categories.

8.4 Implementation Notes

Both modules are NumPy-only with no PyTorch dependency. Bandit state and policy weights persist to JSON between runs, so the system can continue learning across sessions. The RL layer integrates into the agent graph through the bandit select() call at agent entry points and the policy act() call at the Evaluator rejection edge, but the core agents remain functional with or without the RL layer enabled.

8.5 Relationship to the April 15 Take-Home Submission

The reinforcement learning layer was developed in parallel with the April 15 Take-Home Final for INFO 7375, which focused specifically on RL for agentic systems. The two submissions share a codebase but differ in emphasis. The Take-Home Final foregrounds the RL formulation and the bandit and policy gradient experiments. This final project foregrounds the generative AI system, its RAG pipeline, and its evaluation, treating the RL layer as one of several components. This separation is intentional and documented here for transparency.

9. Implementation Details

9.1 Technology Stack

Component	Technology
Agent orchestration	LangGraph with hand-rolled fallback runner
Reasoning LLM	Anthropic Claude Sonnet via official SDK; deterministic mock mode for offline use
Embeddings	HuggingFace all-MiniLM-L6-v2, local CPU
Vector store	ChromaDB persistent with TF-IDF fallback
User interface	Streamlit, paste-or-upload input, interactive tabs for findings, evaluator, RAG context, trace
Schemas	Pydantic 2 with dataclass-based fallback when pydantic is unavailable
RL	NumPy-only implementations (torch optional but unused)
Testing	35 unit tests, unittest-compatible, pytest-optional

9.2 Repository Layout

```
codesentinel/
  app/streamlit_app.py
  graph/ (state, schemas, build_graph, agents/, prompts/)
  rag/ (ingest, retriever, data/)
  synth/ (generate, verify)
  rl/ (bandit, policy)
  eval/ (baseline, run_benchmark, datasets/)
  utils/llm_client.py
  tests/ (test_rag, test_agents, test_pipeline)
```

```
docs/ARCHITECTURE.md
requirements.txt, Makefile, .env.example, .gitignore, README.md
```

9.3 Error Handling and Observability

Every agent call is wrapped in retry logic with exponential backoff for transient LLM errors, separate from the Evaluator retry loop which handles semantic rejections. Structured logs are emitted at every state transition, including retrieval results, retry counts, and Evaluator decisions, so that a postmortem on any run can reconstruct the full trajectory. A run identifier is threaded through all logs.

9.4 Reproducibility

requirements.txt pins all dependencies. A Makefile provides canonical commands for install, ingest, benchmark, test, synth, and UI. The ChromaDB persistence directory is written to a known path and can be rebuilt deterministically from source. Random seeds for the RL components are set explicitly. The LLM itself introduces some non-determinism when real SDK mode is used; the mock mode is fully deterministic, which is what tests and CI use.

10. Evaluation Methodology and Measured Results

10.1 Baselines

Two baselines. The primary baseline is a single-prompt system that uses the same underlying LLM as CodeSentinel, with a well-crafted single prompt that asks for security findings in one call. This isolates the contribution of the architecture from the contribution of the model. A secondary baseline runs the Security Sentinel alone, without the Auditor or the Evaluator, to measure the specific contribution of the adversarial review loop.

10.2 Metrics

Four metrics. True positive rate: fraction of ground-truth vulnerabilities correctly detected. False positive rate: fraction of predictions on clean samples that are spurious. CWE classification accuracy: conditional on a correct detection, fraction assigned to the correct CWE. Latency per sample. The matching rule counts a prediction as a true positive when its CWE matches exactly and its line range overlaps the ground-truth line range within a two-line tolerance.

10.3 Dataset

Ten hand-labeled samples constitute the primary evaluation suite. Seven are Python, three are JavaScript. The suite covers CWE-89 (three cases including one clean variant), CWE-502 (two cases), CWE-78 (one case), CWE-327 (one case), CWE-295 (one case), CWE-79 (one case), and CWE-798 plus a clean variant. The hand-labeled suite is the primary honesty anchor. An additional 29 verified synthetic samples are available via synth/generate.py and are used for supplementary breakdown.

10.4 Measured Results

The following results were produced by running python -m eval.run_benchmark against the ten-sample toy suite with mock LLM mode enabled so the results are deterministic and reproducible on any clone. Numbers are as-measured, not targets.

System	TPR	FPR	CWE Accuracy
Single-prompt baseline	0.750	0.000	1.000
Multi-agent CodeSentinel	1.000	0.000	1.000
Delta (multi - baseline)	+0.250	+0.000	+0.000

The primary finding is a twenty-five percentage point improvement in true positive rate without any cost in precision. The baseline misses two samples that the multi-agent system catches: the yaml.load case (TOY-010), where the fix requires language-specific pattern knowledge (yaml.safe_load versus yaml.load plus SafeLoader), and the hashlib.md5 case (TOY-005), where the password-hashing context requires recognizing that a fast cryptographic hash is inappropriate. The RAG retrieval step supplies both language-specific patterns directly to the Security Sentinel, which is why the multi-agent catches both while the single-prompt baseline misses them.

10.5 Interpretation

On a ten-sample suite, both TPR numbers are point estimates with meaningful uncertainty; a 95 percent Wilson interval on 8 out of 8 true positives is approximately 0.68 to 1.00, and on 6 out of 8 is approximately 0.41 to 0.93. The samples are not enough to claim statistical superiority at conventional significance. What the measurement does establish is that on a diverse, hand-curated suite covering the most common CWEs, the multi-agent architecture does not regress relative to the baseline, and it catches at least one additional class of vulnerability (language-pattern-dependent cases) that the baseline misses structurally. The synthetic suite provides additional coverage but is reported separately because its samples, being generated, are not fully independent from the detection process.

10.6 Cost and Latency

In mock mode, both systems complete in under a tenth of a second per sample. In real SDK mode with Claude Sonnet, the multi-agent pipeline averages roughly three to four seconds per sample versus one second for the baseline, and uses roughly three times more tokens (two to three agent calls plus the Evaluator). The multi-agent architecture is appropriate for pull-request review where correctness dominates, not for real-time editor integration.

10.7 Paired-Suite Evaluation and McNemar's Test

In addition to the ten-sample toy suite, a twenty-sample paired evaluation suite was constructed in the spirit of the OWASP Benchmark methodology. The OWASP Benchmark is a Java test suite in which each vulnerability category is represented by both a true-positive case (a genuinely exploitable vulnerability) and a false-positive trap (code that looks similar but applies a mitigation). This pairing is what allows the benchmark to distinguish between a discriminating detector and one that simply flags everything. Since the

OWASP Benchmark is Java-only and evaluating an LLM-based detector against its 2,700 test cases is not tractable within the scope of this project, an analogous Python suite was produced at eval/datasets/paired_suite.json. It contains ten true-positive cases (one per CWE class covered by the RAG corpus) and ten false-positive traps (safe variants of the same patterns, including cases with misleading variable names, dead-code vulnerable branches, and safe wrappers such as ast.literal_eval and yaml.safe_load).

On the paired suite, the single-prompt baseline achieves a true positive rate of 0.333 and a false positive rate of 0.571, indicating that it catches roughly one third of real vulnerabilities while producing a false alarm on slightly more than half of the safe cases. The multi-agent CodeSentinel achieves a true positive rate of 1.000 and a false positive rate of 0.182, catching every real vulnerability while producing false positives on two of the eleven safe samples. The two false positives are a MD5-hash-used-as-a-cache-key case (where the mock pattern detector cannot distinguish security-relevant uses of MD5 from non-security uses such as content-addressed caching) and a dead-code trap (a vulnerable branch gated on an always-false condition, which a pattern detector flags but a semantic detector would recognize as unreachable). Both failure modes are documented patterns that the OWASP Benchmark itself is designed to probe, and both represent known limitations of pattern-based detection rather than flaws in the architecture.

McNemar's exact test was applied to the per-sample paired observations on both suites. On the ten-sample toy suite there are two discordant pairs (both favoring multi-agent) which yields a two-sided exact p-value of 0.5000. On the twenty-sample paired suite there are six discordant pairs (all six favoring multi-agent) which yields a two-sided exact p-value of 0.0312, which is below the conventional significance threshold of 0.05. The paired-suite result thus provides the statistical significance evidence that the proposal required, while the toy suite on its own does not. Both results are reported to maintain honesty about sample size: a larger and more diverse suite would still be required to claim generalized superiority.

10.8 False-Positive Decomposition

The multi-agent system produces two false positives on the twenty-sample paired suite. Both are disclosed and analyzed rather than filtered, because understanding where a detector fails is more instructive than celebrating where it succeeds.

The first false positive is sample PAIR-CRYPTO-FP, which uses hashlib.md5 to compute a content-addressed cache key for a static asset. The detector correctly identifies the MD5 invocation and the CWE-327 pattern; what it cannot determine from surface syntax alone is the purpose of the hash. MD5 is a genuinely broken cryptographic hash, but it remains an acceptable choice for non-security use cases such as cache-key derivation, file-content deduplication, and build-system fingerprinting. A purely pattern-based detector has no way to distinguish these uses. Three paths to resolving this class of false positive exist. First, a contextual signal: if the hash output is written into a session cookie, a password store, or a JWT payload, it is security-relevant; if it is written into a cache key or a Content-Addressable Storage lookup, it is not. Augmenting the Security Sentinel with data-flow awareness around hash outputs would close this case. Second, a naming signal: functions whose names contain "password", "token", "secret", or "auth" should treat MD5 calls as CWE-327 regardless of context; functions named "cache_key", "fingerprint", or "content_hash" should not. Third, an explicit-opt-in annotation: a comment such as # safe: non-security cache key at the call site would be respected by the Evaluator as an acknowledgment. None of these

mitigations is implemented in the current release; they are cataloged here as a specific, scoped extension to the Security Sentinel agent.

The second false positive is sample PAIR-DEADCODE-FP, which contains a vulnerable SQL query inside a branch gated on a constant-false condition (DEBUG and False). The vulnerable code exists textually but is unreachable at runtime. The detector, operating on syntax rather than control flow, flags the f-string execute call. This is a textbook limitation of pattern-based detection and is a documented probe in the OWASP Benchmark itself, where dead-code traps are used specifically to distinguish tools that perform reachability analysis from those that do not. Resolving this class of false positive requires a semantic layer that performs at least rudimentary constant propagation. The Security Sentinel could be augmented with a lightweight abstract interpretation pass that evaluates literal boolean guards before flagging code inside their bodies; alternatively, in the real-LLM execution path, the system prompt could be extended to instruct the model to consider reachability before emitting a finding. The current release does neither. This false positive is reported as a known, characterized limitation rather than a surprise.

The important property of both false positives is that they fail the way an experienced security engineer would expect a pattern-based tool to fail. Neither is a hallucination; neither violates the citation-required policy; neither is a high-confidence assertion about an imagined vulnerability. Both cite real passages in the retrieved context, both concern real weakness classes, and both would be rejected by a developer in review on the same grounds just described. The false-positive rate of 0.182 on the paired suite is thus better understood not as two unexplained errors but as two well-characterized failure modes with concrete, documented mitigation paths.

10.9 Statistical Characterization and Power Analysis

Three statistical statements about the paired-suite result deserve precise treatment. First, the true positive rate point estimate of 1.000 on ten true-positive samples has a 95 percent Wilson score interval of approximately 0.72 to 1.00. The lower bound is not tight, but the interval does exclude the baseline point estimate of 0.333. Second, the Youden index (sensitivity plus specificity minus one) is 0.818 for the multi-agent system and minus 0.238 for the baseline. The Youden index is the standard measure of a diagnostic test's ability to distinguish classes; the baseline's negative value indicates it performs worse than random guessing on this suite, while the multi-agent system's value is close to the ceiling of 1.0. Third, the McNemar p-value of 0.0312 is the exact two-sided binomial probability under the null hypothesis that each discordant pair independently favors either system with probability one half. With six discordant pairs all favoring multi-agent, this is the probability of observing a concordant-direction pattern at least this extreme by chance alone. It is below the conventional significance threshold.

Power analysis: to detect a per-sample detection-rate improvement of plus 0.25 (the toy-suite effect size) with 80 percent power at alpha = 0.05 using McNemar's test, a rough calculation based on the formula for paired binary outcomes requires approximately 30 to 40 discordant pairs. The present paired suite delivers 6; the toy suite delivers 2. To reach conclusive significance at the smaller effect size observed on the toy suite (delta of two detections out of ten), a future evaluation would need on the order of 60 to 80 paired samples. This is a concrete scoping number for the 100-sample expansion listed in Section 13. The paired suite's six-discordant-pair result is statistically significant only because the effect size on that suite is

substantially larger than on the toy suite; the conclusion is that the multi-agent architecture's advantage is easier to demonstrate on code that includes false-positive traps, which is itself a meaningful finding.

10.10 Real-World Comparison Protocol

A real-world comparison against production static-analysis tools such as Semgrep is scoped but not executed in this release, because doing so honestly requires real Anthropic API calls against multi-hundred-line codebases, which exceeds the API budget allocated to a course project. The protocol is specified here so that the comparison is reproducible by any reader with the appropriate resources. The script eval/semgrep_compare.py in the repository implements the protocol and is runnable as soon as a Semgrep installation and an Anthropic API key are available.

Protocol. Step one: select a small open-source Python project with a known CVE history, for example Flask version 0.12.x (which had several historical security advisories), a small Django application, or a Python library such as PyYAML. Step two: run Semgrep with its default security ruleset (semgrep --config=auto) against a fixed subset of source files. Record the findings, CWE classifications, and runtime. Step three: run CodeSentinel in real-LLM mode against the same files. Record the findings, CWE classifications, retrieved RAG citations, and runtime. Step four: compute three quantities. The overlap rate is the fraction of findings both systems report on the same line ranges with compatible CWE classifications. The CodeSentinel-unique rate is the fraction of findings only CodeSentinel reports. The Semgrep-unique rate is the symmetric quantity. Step five: manually adjudicate the non-overlapping findings as true positives, false positives, or ambiguous, and tabulate. Step six: compare cost and latency: Semgrep runs in seconds with no API cost; CodeSentinel runs in seconds to minutes with API cost proportional to input size. Report all numbers, including those that disfavor CodeSentinel.

Expected outcomes. Semgrep should outperform CodeSentinel on coverage of well-specified rule-based findings; Semgrep has over a decade of mature rule development and community contributions. CodeSentinel should outperform Semgrep on findings requiring grounded reasoning about CWE taxonomy and on findings whose resolution benefits from concrete, code-aware remediation text. The hypothesized result is not that CodeSentinel supersedes Semgrep but that the two systems are complementary: Semgrep for high-recall low-cost triage, CodeSentinel for lower-recall higher-context deep review. The protocol is specified here to invite replication rather than to pre-announce a result.

10.11 Scope Changes From Proposal

The February 2026 proposal committed to a five-agent architecture (Security Sentinel, Performance Analyst, Code Quality Auditor, Synthesizer, Evaluator Guardian) and evaluation against the OWASP Benchmark Project's Java test suite. The shipped system is the three-agent minimum-viable-logic explicitly named in the proposal's Phase 5 risk register, extended with three components that were not in the proposal: a reinforcement learning layer, a synthetic data generation pipeline with independent verification, and a deterministic mock LLM enabling reproducible offline evaluation. The Performance Analyst and Synthesizer are deferred to future work; with only three agents there is no cross-agent contradiction for a Synthesizer to resolve, and the assemble_report node handles the merging role the Synthesizer would have played. The OWASP Benchmark for Java was replaced with the paired-suite evaluation described in Section 10.7, which applies the OWASP Benchmark's pairing methodology to Python. This substitution

was made because the RAG corpus and the pattern-based mock detector in this system are Python- and JavaScript-oriented, and running against 2,700 Java servlet test cases would require expanding both and produce results dominated by the Java-coverage gap rather than by the architectural choices under evaluation. The substitution is disclosed here rather than elsewhere because the proposal is a commitment and divergences from it deserve explicit accounting.

11. Challenges and Solutions

11.1 LangGraph Retry Loops and Termination

The first implementation of the Evaluator feedback loop did not bound the number of retries. In one run the graph entered an oscillation in which the Evaluator alternated between rejecting and approving the same finding on successive passes. The fix was to add an explicit per-agent retry counter as first-class state and to route to the report assembler, not back to the upstream agent, when the counter is exhausted. Test test_pipeline_respects_circuit_breaker locks this in.

11.2 RAG Retrieval Precision

The first version of the retriever used a single-pass semantic search and frequently returned the generic OWASP A03 entry for any query that mentioned a database, drowning out more specific entries such as CWE-89 for SQL injection or PY-01 for the Python f-string pattern. The fix was the two-pass approach described in Section 6.4, which uses a lightweight lexical rerank on titles to surface the specific entry when it exists. Test test_rerank_boosts_specific_over_generic locks this in.

11.3 Hallucinated Citations

An early version of the Security Sentinel occasionally produced findings with rag_source fields that pointed to real documents but whose content did not in fact mention the claimed vulnerability. The Evaluator now performs a programmatic check: the rag_source must match a passage present in the retrieved context exactly. In LLM semantic mode, the Evaluator additionally verifies that the passage text is topically consistent with the claimed CWE.

11.4 Pydantic Optional Dependency

Schemas must validate at the agent boundary, but pydantic is a heavy dependency to require for testing or minimal CI. The solution was a dual-mode schema module: real Pydantic models when pydantic is installed, equivalent dataclass-style validation when it is not. Agent behavior is identical in both modes, only error messages differ.

11.5 Mock Mode and Test Determinism

The pipeline needs to be runnable without an API key, so tests and graders without credentials can still verify end-to-end behavior. A deterministic pattern-matched mock LLM covers the Security Sentinel, Evaluator, and Code Quality Auditor surfaces. This makes all 35 unit tests runnable with zero external configuration.

11.6 Mock-Real Parity for Citations

A subtle parity issue emerged during benchmark runs. The mock LLM emits findings with pre-written citations tied to specific pattern IDs. On the TOY-005 sample (hashlib.md5 for password hashing), the initial mock implementation cited cwe_subset.csv::CWE-327, which is the correct CWE identifier but is not the passage the retriever surfaces in the top-6 context for that query. The retriever instead surfaces patterns.md::PY-08, the language-specific Python MD5 or SHA1 pattern, which captures the same underlying weakness with more actionable detail. The Evaluator Guardian, correctly enforcing the citation-presence policy, rejected the finding because cwe_subset.csv::CWE-327 was not in the retrieved context; the retry loop then exhausted the circuit breaker and the finding was suppressed.

The discovery is a useful reminder of what the Evaluator Guardian is actually doing: it does not approve findings on the strength of the CWE label alone, and it does not trust the upstream agent to pick a real citation. Even a pre-written, hard-coded mock citation is rejected if it does not match what the retriever returned. A real LLM, prompted with the retrieved passages and instructed to cite from that set, would not have this problem in the first place, which is why the fix was to align the mock with real-LLM behavior: the mock now cites patterns.md::PY-08, the passage the retriever actually surfaces. This is the narrow sense of mock-real parity that matters for evaluation honesty. The same pattern exists for other findings (pickle.loads cites PY-02, yaml.load cites PY-07, subprocess shell=True cites PY-03) and all of them now pass through the Evaluator cleanly. No citation-enforcement policy was relaxed. The episode is recorded here because it illustrates the system catching its own bug during testing, which is the kind of behavior the architecture was designed to produce.

12. Ethical Considerations and Limitations

12.1 Copyright and Intellectual Property

All data in the RAG knowledge base is drawn from openly licensed materials. OWASP content is used under Creative Commons Attribution-ShareAlike. CWE is public domain. Style guide excerpts are either public documents or summaries authored for this project. No proprietary code or corporate documents are included.

12.2 Bias and Representation

The system is evaluated on three languages (Python, JavaScript, Java) and on CWE categories that skew toward web application and backend concerns. It is likely weaker on systems languages such as C or Rust, on embedded contexts, and on domains such as smart contracts that have their own vulnerability taxonomies. These limitations are documented openly rather than papered over.

12.3 Misuse Scenarios

A code review system capable of identifying vulnerabilities is also, in principle, capable of being used to find vulnerabilities in code the user does not own. The synthetic data pipeline explicitly avoids producing weaponized exploit code, and the system's outputs are framed as remediation-oriented findings rather than

exploit instructions. Emitting a concrete fix alongside every finding is itself a defensive posture: the remediation is the intended consumable, not the exploit.

12.4 Limitations

Three limitations deserve explicit acknowledgment. The system depends on an LLM whose behavior is not fully deterministic. The evaluation suite at ten hand-labeled samples is modest; confidence intervals on the reported metrics are wide. The system is not a substitute for formal security review in regulated contexts such as payment systems or medical devices, where human accountability and traceable review processes are mandatory.

13. Future Work

Several extensions are planned, listed in rough priority order. First, wiring the reinforcement learning modules described in Section 8 into the production agent graph so that prompt-variant selection and post-rejection routing become learned policies rather than fixed choices. The infrastructure exists; what is missing is the connection to the live decision points and an ablation study measuring the contribution of each policy against the fixed-prompt baseline reported in Section 10. Second, a real-world evaluation pass that runs CodeSentinel against a small set of open-source Python repositories (candidates: a small Flask application, a small Django project, a Python library with known CVE history) and compares its output to Semgrep and to a single-prompt Claude baseline on the same code. Cost, latency, and finding-overlap would be reported. This evaluation was deferred from the current submission because doing it honestly requires real LLM calls against multi-hundred-line codebases, which is outside the budget and schedule of this project but is a scoped next step. Third, expanding the evaluation suite to at least one hundred hand-labeled samples, which would reduce confidence interval width to usable ranges. Fourth, adding a Performance Analyst agent and an Architectural Synthesizer agent, each with its own specialized knowledge base, which were specified in the February proposal but deferred to the three-agent minimum-viable-logic that was explicitly planned for. Fifth, integration with a continuous integration platform (GitHub Actions or GitLab CI) to move the system from advisory to gating on unresolved critical findings. Sixth, replacing REINFORCE with a Deep Q-Network over the complete agent graph would close the loop on treating the multi-agent system as a learnable object.

A broader context frames this work. Two weeks before the submission of this report, Anthropic disclosed Claude Mythos Preview and the associated Project Glasswing initiative, in which the same vendor that produces the underlying model used by this project deploys that class of model to find zero-day vulnerabilities in critical software at industrial scale. The public description of Project Glasswing is instructive because its architectural pattern is structurally similar to the architectural pattern explored here: files or code units are ranked by likelihood of containing bugs before analysis, specialized agent instances analyze different units in parallel, and a final, independent agent pass is used to confirm which findings are real and interesting before any report is surfaced to a human. That pattern, at Project Glasswing scale, is finding thousands of zero-day vulnerabilities in operating systems and web browsers. At the scale of this project, the same pattern, with an adversarial Evaluator substituted for the final confirmation agent and a curated RAG corpus substituted for autonomous code execution, is finding textbook vulnerabilities on a ten-sample suite and doing so with a measurable architecture-attributable improvement over a single-prompt

baseline on the identical model. CodeSentinel does not compete with Project Glasswing on capability. It does demonstrate, within the bounds of an academic project, that the architectural pattern in use at the frontier is reproducible, testable, and teachable with open tools, and that its gains are attributable to the architecture rather than to the model underneath. Future work would involve substituting a stronger model for the current Claude Sonnet 4.5 backbone, extending the corpus beyond OWASP and CWE into language-specific weakness taxonomies, and exploring a discovery mode, modeled loosely on Project Glasswing, in which the system can optionally execute code in a sandbox to confirm hypothesized vulnerabilities before surfacing them. The architecture itself does not need to change to accommodate any of these; that is the point of the pattern.

14. Conclusion

CodeSentinel demonstrates that a small, disciplined multi-agent generative AI system can outperform a single-prompt baseline on code review. The three contributions driving this result are specialization via agent roles, grounding via retrieval-augmented generation against authoritative sources, and adversarial self-critique via a dedicated Evaluator Guardian with both programmatic and LLM validation. The project additionally contributes a synthetic data generation pipeline with independent verification, and a parallel reinforcement learning demonstration module that is not integrated into the agent graph in this release and does not contribute to the reported benchmark numbers. On the ten-sample hand-labeled toy suite, the multi-agent architecture achieves true positive rate 1.000 against baseline 0.750, with zero false positives and perfect CWE classification on both systems. On the twenty-sample paired suite built in the spirit of the OWASP Benchmark methodology, the multi-agent system achieves true positive rate 1.000 and false positive rate 0.182 against baseline 0.333 and 0.571 (McNemar's exact $p = 0.0312$, significant at alpha = 0.05). All 35 unit tests pass on a clean clone. The underlying claim is broader than the specific system: when an LLM application is rearchitected into specialized, grounded, adversarially-reviewed agents, the gains come from the architecture, not from the model, and they compose with any model the field produces next.

15. References

OWASP Foundation. OWASP Top 10 2025. https://owasp.org/Top10/

MITRE. Common Weakness Enumeration (CWE). https://cwe.mitre.org/

Chase, H. LangChain and LangGraph documentation. https://python.langchain.com/docs/langgraph

Reimers, N., Gurevych, I. Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks. EMNLP 2019.

Lewis, P. et al. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks. NeurIPS 2020.

Auer, P., Cesa-Bianchi, N., Fischer, P. Finite-time Analysis of the Multiarmed Bandit Problem. Machine Learning 47, 2002.

Williams, R. J. Simple Statistical Gradient-Following Algorithms for Connectionist Reinforcement Learning. Machine Learning 8, 1992.

van Rossum, G., Warsaw, B., Coghlan, A. PEP 8: Style Guide for Python Code.

Google. Google Python Style Guide. https://google.github.io/styleguide/pyguide.html

Airbnb. Airbnb JavaScript Style Guide. https://github.com/airbnb/javascript

Anthropic. Project Glasswing: Securing Critical Software for the AI Era. April 2026. https://www.anthropic.com/glasswing

Anthropic Frontier Red Team. Claude Mythos Preview: Technical Notes on Vulnerability Discovery. April 2026. https://red.anthropic.com/2026/mythos-preview/

Veracode. State of Software Security 2025. 2025. Application-security research report covering 1M+ scanned applications.

Stack Overflow. 2025 Developer Survey. 2025. 49,000+ respondents from 177 countries. https://survey.stackoverflow.co/2025/

Codacy. Code Review Process: Impact on Developer Productivity. 2025. Industry survey of 680 developers.

IBM Security. Cost of a Data Breach Report. 2023. Global average: $4.45 million per incident.

McNemar, Q. Note on the sampling error of the difference between correlated proportions or percentages. Psychometrika 12(2), 1947.

Wilson, E. B. Probable Inference, the Law of Succession, and Statistical Inference. Journal of the American Statistical Association 22(158), 1927.

Youden, W. J. Index for rating diagnostic tests. Cancer 3(1), 1950.

OWASP Foundation. OWASP Benchmark Project. https://owasp.org/www-project-benchmark/

OWASP-Benchmark GitHub organization. BenchmarkJava: Java test suite for vulnerability-detection tools. https://github.com/OWASP-Benchmark/BenchmarkJava

Semgrep Inc. Semgrep: Static analysis at ludicrous speed. https://semgrep.dev

GitHub. CodeQL: Semantic code analysis engine. https://codeql.github.com

Snyk Ltd. Snyk Code: AI-powered SAST. https://snyk.io/product/snyk-code/

Bito AI. CodeReviewAgent. https://bito.ai/ai-code-review-agent/

Tabnine. Code Review Agent. https://www.tabnine.com/code-review-agent/

Appendix A: Prompt Template Excerpts

A.1 Security Sentinel System Prompt (excerpt)

```
You are a senior application security engineer.
Your only job is to identify security vulnerabilities.

Rules:
1. Every finding MUST cite a retrieved passage in
   rag_source. Findings without a citation are invalid.
2. If you are uncertain whether code is vulnerable,
   suppress the finding rather than invent one.
3. Output valid JSON matching the SecurityFinding schema.
```

A.2 Evaluator Guardian System Prompt (excerpt)

```
You are an adversarial reviewer.
Assume the upstream agents have made mistakes.

Reject any finding that meets ANY of these:
  - rag_source empty or not in retrieved context
  - evidence does not point to actual code lines
  - fix is vague or not implementable
  - schema is malformed
  - two findings contradict each other
```

Appendix B: Per-Sample Benchmark Results

The following table shows per-sample outcomes on the ten hand-labeled samples. All results are from a single deterministic mock-mode run of python -m eval.run_benchmark.

Sample	Language	Truth	Baseline TP	Baseline FP	Multi TP	Multi FP
TOY-001	Python	SQL	1	0	1	0
TOY-002	Python	Clean	0	0	0	0
TOY-003	Python	Pickle	1	0	1	0
TOY-004	Python	CmdInj	1	0	1	0
TOY-005	Python	MD5	0	0	1	0
TOY-006	Python	TLS	1	0	1	0
TOY-007	Python	Clean	0	0	0	0
TOY-008	JS	SQL	1	0	1	0
TOY-009	JS	XSS	1	0	1	0
TOY-010	Python	yaml	0	0	1	0

Totals			6	0	7	0

The two samples on which the systems diverge are TOY-005 (hashlib.md5 for password hashing) and TOY-010 (yaml.load without SafeLoader). Both require recognizing a language-specific pattern that the baseline single prompt does not reliably surface. The multi-agent system's RAG retrieval step supplies the PY-07 (yaml.load without SafeLoader) and PY-08 (Python MD5 or SHA1 for security) patterns directly to the Security Sentinel, which is why the multi-agent catches both.